

MSP logo



Strategic IT Roadmap

| Executive Narrative

This engagement was commissioned to give Meridian-Logistics a defensible path to two specific compliance outcomes and one operational outcome: attestation under the NIS2 Directive within a 12-month horizon (G-01), a TISAX label at the December 2026 assessment (G-02), and a working, exercised Incident Response process (G-03). The three goals are tightly coupled — the TISAX assessment and the NIS2 attestation share evidentiary requirements around incident response, monitoring, business continuity, and policy maturity, and a credible IR process is a precondition for both. The work therefore frames a single coherent programme rather than three parallel tracks. [inferred] [source:from: GAP-002 + GAP-004 + RMI-009] [conf:H]

The current situation is shaped by a 2025 ransomware incident that encrypted important VMs and ended in a paid ransom because the response capability was inadequate. Two preventative service contracts (Device Hardening and Mail Security) and the IT Change Management service all lapsed on 2026-05-25, leaving the estate measurably more exposed than it was the day before this engagement opened. The contracted IAM Gold service includes MFA, but enforcement has not been confirmed because of staff resistance, and the security policy framework is outdated and not in active use. There is no SIEM, no Business Continuity service, no Network Detection and Response, and no Threat Intelligence in the estate. [inferred] [source:from: GAP-004 + GAP-005 + GAP-006] [conf:H]

Three gaps are rated critical and each maps directly to the ransomware lesson and to the compliance regimes in scope. GAP-001 (no SIEM or centralised security monitoring) means the organisation cannot detect an active intrusion in time to interrupt it. GAP-002 (no Incident Response capability) means that when an event is detected there is no rehearsed, role-clear process to contain and recover from it. GAP-003 (no Business Continuity Plan or BC service) means that recovery objectives are not defined, tested, or evidenced — a direct finding risk at the TISAX AL2 assessment and a direct material requirement under the NIS2 Directive. Left unaddressed, these three gaps make a repeat ransomware event both more likely and more damaging. [inferred] [source:from: GAP-001 + GAP-002 + GAP-003] [conf:H]

The recommended direction sequences fourteen roadmap items in four capability phases — foundations, enablers, value-drivers, optimisations. Foundations in Q1 Y1 restore baseline integrity by reinstating Mail Security, Device Hardening, and IT Change Management and by deploying IT Asset Management; these are the quick wins that re-establish the controls that lapsed on 2026-05-25. Enablers in Q2-Q3 Y1 layer detection (SIEM), resilience (Business Continuity), governance (IT Risk Management), and identity assurance (MFA enforcement under CEO sponsorship). Value-drivers in late Y1 and H1 Y2 convert capability into TISAX and attestation evidence. The December 2026 TISAX assessment is the dominant near-term forcing function and pulls every TISAX-gating item into Y1. A budget conversation with the

CEO is required before any procurement commitment, because the known programme run-rate exceeds the declared £200k hard limit in a single year. [inferred] [source:from: RMI-001 + RMI-002 + RMI-003 + RMI-005] [conf:H]

By the end of Year 3, Meridian-Logistics should look materially different: the TISAX label retained, NIS2 attestation obtained and entity classification settled with the supervisory authority, an exercised IR process embedded in the organisation, a refreshed and actively-used policy framework, and an annual control review cadence that prevents the kind of silent contract expiry that produced the 2026-05-25 cliff. The shift is from reactive, contract-driven security to a governed, evidenced, and rehearsed operating model. [inferred] [source:from: RMI-013 + RMI-014] [conf:M]

| Key Findings

Finding	Gap addressed	Severity
No SIEM or centralised security monitoring — intrusions cannot be detected in time to interrupt them	GAP-001	critical
No Incident Response capability — no rehearsed process to contain and recover from events	GAP-002	critical
No Business Continuity Plan or BC service — recovery objectives undefined, untested, unevidenced	GAP-003	critical
Information security policy framework is outdated and not in active use	GAP-004	high
MFA enforcement maturity unconfirmed despite contracted IAM capability	GAP-005	high
Device Hardening and Mail Security contracts lapsed on 2026-05-25	GAP-006	high
IT governance informal; Change Management lapsed and in Incident status	GAP-007	high
IT asset inventory incomplete	GAP-008	medium
CMP-001 entity classification not	GAP-009	medium

Finding	Gap addressed	Severity
validated with national supervisory authority		

| Roadmap Summary

RMI-id	Title	Year	Phase	Owner	Compliance role	Quick win
RMI-001	Reinstate Mail Security contract	Y1	foundations	Izayoi Nayuta (CISO)	constraint	✓
RMI-002	Reinstate Device Hardening contract	Y1	foundations	Izayoi Nayuta (CISO)	constraint	✓
RMI-003	Reinstate and resolve IT Change Management	Y1	foundations	Izayoi Nayuta (CISO)	constraint	✓
RMI-004	Deploy IT Asset Management	Y1	foundations	Izayoi Nayuta (CISO)	constraint	
RMI-005	Enforce MFA via contracted IAM capability	Y1	enablers	Izayoi Nayuta (CISO), sponsored by Cheng Zebang (CEO)	constraint	✓
RMI-006	Deploy SIEM for centralised security monitoring	Y1	enablers	Izayoi Nayuta (CISO)	deadline (2026-12-01)	
RMI-007	Deploy IT Risk Management for governance framework	Y1	enablers	Izayoi Nayuta (CISO)	constraint	
RMI-008	Deploy Business Continuity service (IR capability and BCP)	Y1	enablers	Izayoi Nayuta (CISO)	deadline (2026-12-01)	
RMI-009	BCP documentation and IR	Y1	value-drivers	Izayoi Nayuta (CISO)	deadline (2026-12-01)	

RMI-id	Title	Year	Phase	Owner	Compliance role	Quick win
	tabletop exercise					
RMI-010	Pre-assessment audit readiness review (CMP-002)	Y1	value-drivers	Izayoi Nayuta (CISO)	deadline (2026-12-01)	
RMI-011	Engage legal/regulatory advisory for entity classification (CMP-001)	Y2	optimisations	Izayoi Nayuta (CISO), escalation to Cheng Zebang (CEO)	deadline (2027-05-26)	
RMI-012	Information security policy framework refresh	Y2	value-drivers	Izayoi Nayuta (CISO)	deadline (2027-05-26)	
RMI-013	Compliance attestation programme (CMP-001)	Y2	value-drivers	Izayoi Nayuta (CISO)	deadline (2027-05-26)	
RMI-014	Sustained operations and annual control review	Y3	optimisations	Izayoi Nayuta (CISO)	enabler	

Decision Log

DEC-id	Decision	Date	Decided by	Notes
—	No decisions recorded during this engagement	—	—	—

| Assumption Register

ASM-id	Assumption	Confidence	Status	Revalidation	Invalidates if wrong
ASM-001	No earlier national supervisory authority enforcement date exists requiring attestation before the 12-month horizon	M	Validated in phase 01 — no supervisory authority contact received	No longer required	NIS2 attestation horizon may be shorter than planned
ASM-002	MSP is contracted and resourced to deliver security controls beyond internal IT team basics; exact responsibility split deferred to phase 03-mapping	M	Open — not explicitly resolved in phase 03	Yes — flag for revalidation before procurement commitment	Internal IT team bears more delivery responsibility than scoped
ASM-003	TISAX assessment is at Assessment Level 2 (AL2); if AL3, scope increases materially	M	Confirmed in phase 01 — TISAX is at AL2	No further revalidation required	TISAX scope and effort increase materially

| Risk Log

RSK-id	Risk	Likelihood	Impact	Status	Mitigation
RSK-001	TISAX AL2 assessment failure — December 2026	H	H	open	Accelerate IR and policy workstreams; prioritise all TISAX-gating items for delivery before October 2026 to allow a pre-assessment dry run (RMI-008, RMI-009, RMI-010)
RSK-002	NIS2 compliance failure within 12-month horizon	H	H	open	Deploy SIEM, Business Continuity, and IR process as highest-priority items (RMI-006, RMI-008); validate entity classification (RMI-011); attestation programme (RMI-013)
RSK-003	Repeat ransomware attack due to unresolved detection and response gaps	H	H	open	Reinstate Mail Security and Device Hardening immediately (RMI-001, RMI-002); deploy SIEM by end Q2 Y1 (RMI-006); IR process and tabletop by Q3 Y1 (RMI-008, RMI-009)

RSK-id	Risk	Likelihood	Impact	Status	Mitigation
RSK-004	Security regression from contract expiry (Device Hardening, Mail Security, IT Change Mgmt)	M	H	open	Confirm renewal decisions Q1 Y1 (RMI-001, RMI-002, RMI-003); annual review prevents recurrence (RMI-014)
RSK-005	IAM control effectiveness undermined by organisational resistance to MFA	M	H	open	CEO sponsorship, firm enforcement deadline (end Q2 Y1), change-management workstream (RMI-005)

| Contradictions Surfaced This Phase

CON-id	Contradiction	Status	Resolution
—	No contradictions surfaced or outstanding	resolved	n/a

| HITL Confirmation Record

Gate	Timestamp	Consultant confirmation
Gate 1 — entry confirm	2026-05-26T12:00:00Z	All six entry checklist items confirmed YES
Gate 3 — ratification	2026-05-26T12:30:00Z	Consultant confirmed YES — handover.md ratified